

Access Control Worksheet

Cybersecurity Incident Investigation

Incident Summary

An unauthorized deposit was made from the business account to an unknown external bank account. The finance manager denies initiating the transfer. The payment was successfully stopped, but the owner has tasked the cybersecurity team with investigating what happened and preventing future incidents. This worksheet documents the findings from reviewing the event log and employee directory.

Notes — Observations from the Event Log

Note 1

The event log shows that a login was recorded from an IP address that does not match any known internal office range. The user accessed the payroll/payment system at an unusual time (outside normal business hours), which is a strong indicator of unauthorized access.

Note 2

The account used to initiate the transfer belongs to the finance manager; however, cross-referencing the Employee Directory reveals that the login originated from a device and location inconsistent with the manager's typical access patterns, suggesting compromised credentials or an insider threat.

Issues — Access Control Weaknesses Identified

Issue 1 – Overly Permissive Shared Access

The business relies on a single shared cloud drive that all employees access with broad permissions. There is no role-based access control (RBAC) limiting who can view or modify sensitive financial data. This means any compromised account — regardless of the employee's actual role — can reach payment systems.

Issue 2 – No Multi-Factor Authentication (MFA) on Financial Systems

The event log indicates a successful login using only a username and password. The absence of MFA means that stolen or guessed credentials are sufficient to gain full access to payment and payroll functions, leaving the business highly vulnerable to credential-based attacks.

Recommendations — Access Control Mitigations

Recommendation 1 – Implement Role-Based Access Control (RBAC)

Enforce the principle of least privilege across all business systems. Each employee should only have access to the resources necessary for their specific role. Finance-related systems and payment portals should be restricted to authorized personnel only. Establish formal procedures to revoke access immediately when an employee changes roles or leaves the organization.

Recommendation 2 – Enforce Multi-Factor Authentication (MFA)

Require MFA for all logins to sensitive systems, especially those involving financial transactions. MFA ensures that even if a password is compromised, an attacker cannot access the system without a second verification factor (e.g., a one-time code sent to a registered device). This single control would have likely prevented this incident entirely.

Recommendation 3 – Enable Login Anomaly Detection & Alerting

Deploy a Security Information and Event Management (SIEM) tool or configure existing logging systems to alert on anomalous login behavior — such as logins from unfamiliar IP addresses, off-hours access, or rapid privilege escalation. Real-time alerts allow the security team to respond to incidents before significant damage occurs.